

SAS · Perguntas de infraestrutura para produção

Pauta para o time de plataforma do Colégio Ari de Sá · Sistema de acompanhamento das turmas ITM

O objetivo da conversa: o SAS sai da infraestrutura provisória (Supabase + Render + Vercel + AWS) e passa a rodar nos serviços de vocês. Não precisamos que existam esses produtos específicos — precisamos saber o que na casa de vocês cumpre cada papel. O sistema é modesto e já vem containerizado; o que precisa existir é:

- 1 container de API (Python/FastAPI, HTTP)
- 1 site estático (HTML/CSS/JS, sem build)
- 1 banco PostgreSQL
- 1 container PostgREST na frente do banco
- 1 destino de arquivos (bucket ou volume)
- 4 jobs agendados que chamam a própria API
- saída para 2 APIs externas (Canvas e LLM)
- 1 domínio com TLS

FUNDAÇÃO — definem o resto

1 Qual é a nuvem-mãe de vocês e qual é o “caminho pavimentado” — o jeito que 90% das aplicações da casa roda hoje?

E existe catálogo de serviços aprovados? Se precisarmos de algo fora dele, qual é o processo e o prazo? Queremos entrar no padrão de vocês, não criar um décimo-primeiro jeito de fazer deploy.

2 Que serviço de vocês cumpre cada um destes papéis?

A coluna da esquerda é só o que usamos hoje na infra provisória — o que importa é a do meio.

HOJE USAMOS	O PAPEL QUE PRECISA EXISTIR	EQUIVALENTE NA CASA DE VOCÊS
Render	Rodar o container da API	
Vercel	Servir o frontend estático	
Supabase (Postgres)	Banco relacional	
PostgREST (embutido no Supabase)	Traduzir HTTP → SQL — é o que a API de fato consome	
Supabase Storage	Guardar os PDFs de simulado	
AWS EventBridge	POST HTTPS em 4 endpoints, com header custom, com retry	
AWS SSM Parameter Store	Guardar segredos e rotacioná-los	
OpenAI	LLM dos insights e do chat	
— (o Render builda do git)	Registry de imagem + pipeline de deploy	
— (não temos)	Logs, métricas e alerta	

Sobre o agendador: o requisito real é modesto — quatro jobs (sync do Canvas a cada 5 min, alertas e cobrança de hora em hora, reconciliação diária de madrugada), cada um um POST HTTPS autenticado por header. Não precisa de fila nem de entrega exatamente-uma-vez: o sync já coordena por trava em banco, então disparo duplicado não corrompe nada. Um CronJob resolve.

AS QUE MUDAM O CÓDIGO — precisamos saber antes de escrever qualquer linha

3 Dá para rodar um container PostgREST junto da API, com um papel dedicado no banco e sem exposição de rede?

A pergunta mais importante da lista. O backend não escreve SQL: são ~210 chamadas HTTP para o PostgREST, que é exatamente o que o Supabase hospeda por baixo. Entregar “um Postgres gerenciado” não é suficiente. O serviço fica só na rede interna, porque o projeto não usa RLS — toda a autorização vive na API. Se não for possível, o custo é reescrever a camada de dados: é decisão de escopo, não de configuração.

4 A autenticação tem que ser o SSO corporativo (Google Workspace / Entra ID) ou podemos manter credencial própria?

Hoje a API emite o próprio JWT: coordenador por e-mail e senha, aluno por matrícula e senha, com primeiro acesso validado contra o e-mail do Canvas. **Se a política exigir SSO, isso é implementar OIDC e precisa entrar no escopo agora** — não é ajuste de última hora.

5 O uso de uma LLM externa com dados de alunos menores de idade está aprovado pelo jurídico / DPO?

Existe DPA assinado? Em que região os dados podem residir? Qual a política de retenção? **É a pergunta com maior chance de virar um “não” tardio** — sem aprovação, os insights e o chat saem do produto ou trocam de provedor. Se vocês já forem Azure ou AWS, o serviço de LLM da própria nuvem provavelmente resolve isso sob o contrato que vocês já têm.

6 A API fica publicamente acessível ou só na rede interna? E qual é a política de saída para a internet?

Duas consequências diretas. **Se ficar atrás de VPN, o agendador externo não alcança a API** e os 4 jobs viram cron interno. E a API precisa alcançar duas APIs externas — o Canvas e a LLM: existe proxy de saída, precisa de allowlist, o IP de saída é fixo?

AS QUE TRAVAM O GO-LIVE — não mudam código, mas seguram a entrega

7 Como o código chega em produção — e existe ambiente de homologação?

Qual registry recebe a imagem, qual pipeline dispara o deploy, quem aprova, e o nosso time tem acesso? Já entregamos **Dockerfile multi-stage com alvo de produção**, rodando como usuário não-root e escutando a porta que a plataforma injetar.

8 Quem executa as migrations em produção, com qual credencial e em que janela?

Temos runner próprio, com todas as migrations reversíveis, e ele conecta como dono do schema. Precisa de aprovação de DBA? **E o PostgREST tem que ser reiniciado depois de cada migration** — ele lê o schema uma vez, no boot; sem o restart, coluna nova responde 404 mesmo existindo no banco.

9 Quantas réplicas a plataforma de vocês sobe por padrão?

Hoje a API roda com **um worker, de propósito**: o sync do Canvas coordena por trava em banco, o chat responde por streaming e o limitador de tentativas de login é por processo. Rodar N réplicas atrás de um balanceador é possível, mas exige revisar esses três pontos antes — não depois.

10 Backup, observabilidade e plantão: quem é acionado quando cai, e quem é dono do sistema depois do go-live?

Qual a frequência e a retenção do backup, e o restore já foi testado de verdade? Qual a stack de log e alerta (a API escreve em stdout)? Nosso time enxerga log de produção? **E, do lado do Canvas**: de quem é a conta de serviço que gera o token de API, e existe ambiente de teste para homologarmos sem ler produção?

O QUE JÁ VAI PRONTO DO NOSSO LADO

- **Imagem de produção** — multi-stage, não-root, imutável
- **Endpoint de health** para o balanceador
- **Migrations versionadas** e todas reversíveis
- **Stack local** que reproduz produção antes do deploy
- **Guard de boot** que recusa subir com segredo default
- **Configuração 100% por variável de ambiente**

Fora do escopo desta conversa, mas na fila: a cobrança de professores por WhatsApp vai precisar de um gateway aprovado — vale saber desde já se existe algum homologado.